TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

16-year-old EDK II UEFI flaw can run code before Secure Boot on network-booting servers

From **Cybersecurity Briefing 2026-10-29** · 2026-10-28 to 2026-10-29 (last 24 hours; Indiana sections cover 2026-10-24 to 2026-10-29) · Briefing generated 2026-10-29

REPORT ID	VERSION	HANDLING
CTI-20261029-04	1.0 · 2026-10-29 09:06 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
Global	2026-10-28	No update
CVES	**ANALYST**	
CVE-2026-97631 (CVSS 9.5)	Nick Sturgeon	

VULNERABILITY CRITICAL

PATCH AVAILABLE (UPSTREAM FIX MERGED; NO STABLE EDK II RELEASE OR OEM FIRMWARE YET)

OVERALL CONFIDENCE: HIGH

BOTTOM LINE UP FRONT

CVE-2026-97631 is a buffer overflow in the PXE Base Code driver (NetworkPkg/UefiPxeBcDxe) of TianoCore EDK II, the open-source reference code that most commercial UEFI firmware is built from [S3] [S4]. While a machine network-boots, the driver keeps a receive open for ICMP error messages and copies each one into a fixed 504-byte field (Mode.IcmpError). In both the IPv4 and IPv6 handlers the copy loop does not stop at 504 bytes and advances the destination pointer by the cumulative rather than per-fragment length, so an oversized ICMP error writes attacker-controlled bytes past the field [S3] [S6]. The vulnerable loop traces back to a November 2010 commit, which is where the '16-year-old' label comes from [S2]. TianoCore rates it CVSS v4 9.5 (Critical); Red Hat and SUSE score it 8.8 under CVSS 3.1 with an adjacent-network attack vector [S4] [S7] [S12].

An unauthenticated attacker only needs to send a unicast ICMP error to the client's IP address during the PXE boot window. The easy outcome is a deterministic boot hang that blocks OS provisioning or recovery. With knowledge of the exact firmware build, the attacker can plant a counterfeit event in the same packet so that CoreSignalEvent() runs attacker-supplied bytes in the DXE phase, before Secure Boot or measured boot have verified anything [S3] [S6]. The payload runs once and does not persist on its own, but it could be used to install persistent code; Dragos's HD Moore noted the TPM is reachable at that point, which raises a disk-encryption risk [S2]. Systems that boot only from local disk are not exposed. PXE is enabled in EDK II's default build, so exposure is concentrated in servers, data-center and lab equipment, imaging

and provisioning workflows, and virtual machines using EDK II-derived virtual firmware such as OVMF [S2] [S8].

The fix (edk2 PR #13302, merge commit fa789071) was merged to master on 2026-10-15, after a public pull request on 2026-09-28 broke a coordinated disclosure planned for January 2027 [S2] [S5]. The advisory still says 'Not patched currently' because no stable EDK II tag includes the fix; the newest tag, edk2-stable202608, is affected [S2] [S3]. Microsoft's Project Mu has backported it [S9]; Fedora has builds in testing, while Red Hat, SUSE and Debian packages are listed as affected and unfixed [S2] [S8] [S12]. No physical server OEM advisory had been found as of 2026-10-28 [S12]. There is no reported in-the-wild exploitation, no KEV listing, EPSS is about 0.5% [S2] [S13] [S14], and no indicators of compromise have been published.

Defenders should first inventory which hosts and VMs PXE-boot, including fallback boot orders. Disable network boot where it is not needed, and keep PXE and provisioning traffic on isolated, access-controlled segments. Where the network design allows, filter or alert on oversized ICMP or ICMPv6 error messages entering provisioning segments. Apply hypervisor or distribution OVMF/edk2 updates and OEM BIOS/UEFI updates as they ship [S2] [S10] [S11] [S12].

Key judgments

UNLIKELY · MODERATE CONFIDENCE
Over the next 90 days, observed in-the-wild exploitation that achieves pre-boot code execution is unlikely. It needs adjacent or local network position, precise timing during the PXE window, and an exploit tailored to each firmware build. [S2] [S3] [S10]

LIKELY · LOW CONFIDENCE
Public tooling that reliably hangs PXE-booting hosts (the denial-of-service outcome) will likely circulate within weeks. The bug is deterministic and documented in public advisories and pull requests, and a PR commenter has already linked purported proof-of-concept code. [S3] [S5] [S6]

VERY LIKELY · MODERATE CONFIDENCE
Most physical server and workstation OEMs will very likely not ship BIOS/UEFI updates for this CVE before the end of 2026. No stable EDK II release contains the fix, no OEM advisory had appeared by 2026-10-28, and firmware supply-chain patching historically lags upstream by months. [S2] [S3] [S12]

LIKELY · MODERATE CONFIDENCE
Linux distribution OVMF/edk2 packages for virtual machines will likely be fixed well before physical OEM firmware. Fedora builds are already in testing and Project Mu has backported the fix. [S8] [S9] [S12]

UNLIKELY · MODERATE CONFIDENCE
CISA is unlikely to add CVE-2026-97631 to the KEV catalog in the next 30 days without new reporting of exploitation. [S2] [S13] [S14]

INDICATORS OF COMPROMISE

No IOCs (IPs, domains, hashes) have been published for this vulnerability, and no exploitation has been reported. The entries below are technical artifacts from the TianoCore advisory, fix PR and press coverage (2026-10-22 to 2026-10-28), plus derived network patterns for hunting and for checking whether a firmware build carries the fix.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`NetworkPkg/UefiPxeBcDxe`	Vulnerable EDK II PXE Base Code driver module. Firmware or OVMF builds that include this module and predate the fix are affected.	REPORTED	2026-10-22	[S3] [S6]
filepath	`NetworkPkg/UefiPxeBcDxe/PxeBcSupport.c`	Source file that contains the ICMP error copy logic changed by the fix PR.	REPORTED	2026-10-15	[S5]
other	`PxeBcIcmpErrorDpcHandle`	IPv4 ICMP error handler that has the faulty copy loop into the 504-byte Mode.IcmpError field.	REPORTED	2026-10-22	[S3] [S6]
other	`PxeBcIcmp6ErrorDpcHandle`	IPv6 ICMP error handler that has the same faulty copy loop.	REPORTED	2026-10-22	[S3] [S6]
other	`Mode.IcmpError (504-byte field)`	Fixed-size destination buffer in the PXE driver private context that is overflowed.	REPORTED	2026-10-22	[S3]
other	`Unicast ICMPv4 error message (e.g. type 3 Destination Unreachable, type 11 Time Exceeded, type 12 Parameter Problem) with total ICMP message length greater than 504 bytes, possibly IP-fragmented, sent to a host during PXE boot`	The advisory says the trigger is a unicast ICMP error over 504 bytes sent to the client IP during PXE boot. The specific ICMP type numbers listed here are the standard ICMPv4 error types; the sources do not say which types the driver accepts. Treat as a hunting pattern.	DERIVED		[S3] [S6]
other	`Unicast ICMPv6 error message (types 1-4: Destination Unreachable, Packet Too Big, Time Exceeded, Parameter Problem) longer than 504 bytes sent to a host during IPv6 PXE boot`	IPv6 version of the trigger. Types 1-4 are the standard ICMPv6 error types; the sources do not list specific types.	DERIVED		[S3] [S6]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
port	`UDP 67/68, UDP 4011, UDP 69 (IPv6: UDP 546/547)`	Standard DHCP, PXE proxyDHCP and TFTP ports. Traffic on these ports from a client marks the PXE boot window in which malicious ICMP errors would have to arrive. Use for correlation, not as an indicator of attack.	DERIVED		[S3]
other	`fa789071ff0b29f1e568bfe153ef7f3d76bd60e4`	edk2 merge commit for PR #13302 (fix merged to master 2026-10-15). Use it to check whether a firmware or OVMF build includes the fix. Not a malicious indicator.	REPORTED	2026-10-15	[S5] [S8]
other	`64c7b0c9e7a43a9ef6d70943d36aaf5eaef507ec`	edk2 commit titled 'Fix ICMP buffer overflow in IPv4/IPv6 handlers (CVE-2026-97631)'. Use it for build verification.	REPORTED	2026-10-15	[S5]
other	`a3bcde70e6dc69000f85cc5deee98101d2ae200a`	November 2010 edk2 commit that, per The Hacker News' review of project history, introduced the vulnerable copy loop. Builds descended from this commit and lacking the fix are presumed affected.	REPORTED	2010-11-01	[S2]
other	`edk2-stable202608`	Latest stable EDK II tag (2026-08-21). It is affected; affected range is 0 through edk2-stable202608 inclusive.	REPORTED	2026-10-22	[S2] [S4]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker must be able to deliver IP packets to a target while it is PXE-booting over IPv4 or IPv6, usually from the same or an adjacent network segment (an insider, a compromised host on the provisioning VLAN, or a rogue device). During the boot window the UefiPxeBcDxe driver accepts ICMP error messages and copies them into a 504-byte buffer without proper bounds or offset handling. An oversized (possibly fragmented) ICMP error overwrites the driver's private context. A follow-up ICMP error then causes a CPU exception that hangs the boot, which is a reliable denial of service against provisioning and recovery. With a build-specific layout, the attacker

embeds a counterfeit EFI event structure in the same packet so that CoreSignalEvent() dispatches attacker bytes in the DXE phase at the highest privilege. This happens before Secure Boot and measured boot have verified any OS component, so it can be used to stage persistent firmware or boot-chain implants or to reach the TPM [S2] [S3] [S6].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Lateral Movement	T1210 Exploitation of Remote Services	Send a crafted unicast ICMP/ICMPv6 error message larger than 504 bytes to a host's IP during its PXE boot to trigger the UefiPxeBcDxe overflow from an adjacent network position. [S3] [S6]	Alert on oversized ICMP/ICMPv6 error messages entering PXE/provisioning segments, especially from sources that are not routers, and correlate with DHCP/TFTP PXE activity from the destination.
Defense Evasion	T1211 Exploitation for Defense Evasion	Code runs in the DXE phase before Secure Boot and measured boot have verified anything, so OS-level and boot-chain integrity controls are bypassed. [S2] [S3]	Compare TPM PCR measurements and boot attestation against known-good baselines. Investigate unexpected changes after network boots.
Persistence	T1542.001 Pre-OS Boot: System Firmware	The one-time DXE payload could be used to install code that runs at every boot (per press reporting; not observed). [S2]	Run periodic firmware integrity scans (for example CHIPSEC or vendor tools) and compare SPI flash images and firmware versions against vendor-published hashes.
Impact	T1499.004 Endpoint Denial of Service: Application or System Exploitation	Corrupting the PXE driver context so that the next ICMP error causes a DXE CPU exception, hanging boot and blocking OS provisioning or recovery. [S3] [S11]	Watch for clusters of PXE boot hangs or failed provisioning jobs in WDS/MECM/Foreman/MAAS logs, and BMC (iDRAC/iLO/XCC) POST hang events.
Credential Access	T1552 Unsecured Credentials	Researchers warn that hijacking execution at a point where the TPM is accessible could let an attacker defeat TPM-sealed disk encryption with brief network access. This is speculative and has not been observed. [S2]	Watch for unexpected BitLocker/LUKS recovery prompts or TPM unseal anomalies following network boot events.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Suricata - oversized ICMPv4 error toward PXE/provisioning network `SURICATA`

```
alert icmp !$ROUTER_IPS any -> $PXE_NET any (msg:"Possible CVE-2026-97631 - oversized ICMP error to PXE segment"; itype:3; dsize:>480; threshold:type limit, track by_dst, count 1, seconds 60; classtype:attempted-admin; sid:9902601; rev:1;)
alert icmp !$ROUTER_IPS any -> $PXE_NET any (msg:"Possible CVE-2026-97631 - oversized ICMP Time Exceeded to PXE segment"; itype:11; dsize:>480; threshold:type limit, track by_dst, count 1, seconds 60; classtype:attempted-admin; sid:9902602; rev:1;)
alert icmp !$ROUTER_IPS any -> $PXE_NET any (msg:"Possible CVE-2026-97631 - oversized ICMP Parameter Problem to PXE segment"; itype:12; dsize:>480; threshold:type limit, track by_dst, count 1, seconds 60; classtype:attempted-admin; sid:9902603; rev:1;)
```

Define $PXE_NET and $ROUTER_IPS. dsize counts ICMP payload after the 8-byte header, so >480 leaves margin under the 504-byte field. Legitimate ICMP errors usually quote only the IP header plus 8 bytes (IPv4) or up to 1232 bytes (IPv6), so tune per environment. Repeat with ICMPv6 types 1-4 for IPv6 PXE.

Splunk - large ICMP errors to hosts seen PXE booting (Zeek) `SPLUNK SPL`

```
index=zeek sourcetype=zeek_dhcp (msg_types="*DISCOVER*" OR msg_types="*REQUEST*")
(vendor_class="PXEClient*" OR client_fqdn="*")
| eval pxe_host=coalesce(assigned_addr, client_addr)
| table _time pxe_host mac vendor_class
| join type=inner pxe_host max=0 [ search index=zeek sourcetype=zeek_conn proto=icmp | where orig_bytes>480 | rename id.resp_h as pxe_host, id.orig_h as icmp_src | table _time pxe_host icmp_src orig_bytes id.orig_p ]
| stats count min(_time) as first max(_time) as last values(icmp_src) as icmp_sources max(orig_bytes) as max_bytes by pxe_host mac
```

Zeek conn logs record the ICMP type in id.orig_p. Restrict it to error types (3, 11, 12; ICMPv6 1-4) and to time windows within a few minutes of the DHCP event. Field names vary by Zeek/TA version.

KQL - unexpected ICMP error volume toward provisioning subnet (firewall logs) `KQL`

```
CommonSecurityLog
| where TimeGenerated > ago(7d)
| where Protocol in~ ("ICMP", "ICMPv6", "1", "58")
| where ipv4_is_in_range(DestinationIP, "10.0.50.0/24") // replace with PXE/provisioning subnet
| where SentBytes > 500 or ReceivedBytes > 500
| summarize events=count(), maxBytes=max(SentBytes), dsts=dcount(DestinationIP) by SourceIP, DeviceVendor, bin(TimeGenerated, 1h)
| order by events desc
```

Byte fields and protocol naming differ by firewall vendor. Use as a baseline-and-hunt query, not as a high-fidelity alert.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
TianoCore EDK II (NetworkPkg/UefiPxeBcDxe)	All versions through edk2-stable202608 (inclusive)	master at commit fa789071 (PR #13302, merged 2026-10-15); no stable tag yet	CVE-2026-97631	9.5 (CVSS v4, TianoCore); 8.8 (CVSS 3.1 AV:A, Red Hat/SUSE)	0.00483 (41.5th percentile, 2026-10-28)	No	N/A
Microsoft Project Mu (mu_basecore)	release/202608 before backport	Backport PR #1989 merged 2026-10-22; tagged builds reported 2026-10-26	CVE-2026-97631	9.5	0.00483	No	N/A
Linux edk2/OVMF packages (RHEL 8/9/10, SUSE, Debian, Fedora)	RHEL, SUSE and Debian (bookworm, trixie, forky, sid) listed affected/unfixed; Fedora 43-45 fixed builds in testing as of 2026-10-28	Pending distribution updates	CVE-2026-97631	8.8 (Red Hat, preliminary)	0.00483	No	N/A
OEM server/workstation UEFI firmware built on EDK II (AMI, Insyde, Phoenix-based and others)	Unknown; depends on vendor build and whether PXE is enabled	No OEM advisory identified as of 2026-10-28	CVE-2026-97631	9.5	0.00483	No	N/A

Immediate (0–24 hours)

- Inventory systems and VMs that PXE/network boot, including those with PXE in a fallback boot order, plus provisioning servers (WDS, MECM/SCCM PXE distribution points, Foreman, MAAS, iPXE). `IT OPS` [S12]
- On systems that do not need network boot, disable PXE and the UEFI network stack in firmware setup or through BMC/management tooling. `IT OPS` [S2] [S10] [S12]
- Confirm PXE/provisioning VLANs are isolated and access-controlled, so that user, guest and IoT networks cannot reach hosts while they boot. `IT OPS` [S10] [S11] [S12]
- Deploy the oversized-ICMP-error Suricata/IDS rule (or equivalent firewall logging) on provisioning segments, and brief analysts on the PXE boot-hang pattern. `SOC` [S3] [S11]

Short term (1–7 days)

- Open tickets with server, workstation and hypervisor vendors (Dell, HPE, Lenovo, Supermicro, VMware/Broadcom, Microsoft, Nutanix and others) asking for affected status and a firmware timeline for CVE-2026-97631. `IT OPS` [S2] [S11] [S12]
- Where the network design allows, filter inbound ICMP/ICMPv6 error messages to booting hosts at the edges of the provisioning segment. This is derived guidance, not an official workaround; test it so legitimate Path MTU Discovery (PMTUD) and diagnostics still work. `IT OPS` [S11] [S12]
- Apply edk2/OVMF package updates for KVM/QEMU/libvirt and OpenShift virtualization hosts as distributions release them, then restart affected VMs so they load the new firmware. `IT OPS` [S8] [S12]
- Track the vendor advisories, KEV catalog and EPSS for this CVE. Escalate if exploitation or a weaponized code-execution exploit is reported. `SOC` [S13] [S14]

Long term

- Add OEM BIOS/UEFI updates to the regular patch cycle, with BMC-driven rollout and version reporting, so fixes can be deployed when they ship. `IT OPS` [S2]
- Move imaging and recovery to authenticated methods (for example HTTPS boot with certificate validation, or local or USB media) on dedicated provisioning networks. Aim to remove general-purpose PXE. `LEADERSHIP` [S11] [S12]
- Adopt firmware integrity monitoring and boot attestation (TPM PCR baselining) for critical servers. Review CISA/NSA UEFI Secure Boot hardening guidance. `LEADERSHIP` [S11]

Workarounds & compensating controls

- Keep Secure Boot and measured boot enabled. They do not stop this flaw but still protect against other boot-chain threats. `IT OPS` [S12]
- Use pre-boot PINs for BitLocker/LUKS (TPM+PIN) on high-value systems, to reduce the impact of a pre-boot compromise that reaches the TPM. `IT OPS` [S2]
- Use switch protections (DHCP snooping, port security, 802.1X) on provisioning ports to limit rogue devices that could send packets to booting hosts. `IT OPS` [S2] [S12]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: The Hacker News front page (briefing source link)
Published 2026-10-28 · **B2** Usually reliable, probably true
Briefing's original source; headline and teaser only.

[S2] The Hacker News: Critical 16-Year-Old UEFI Flaw Can Run Code Before Secure Boot on Network-Booting Servers
Published 2026-10-28 · **B2** Usually reliable, probably true
Full article. Includes vendor statements (Red Hat, SUSE, Debian, Intel, Arm), origin commit, disclosure timeline and expert comment.

[S3] TianoCore (GitHub Security Advisory): GHSA-99cj-7hg9-mp4m: Pre-boot RCE in EDK II PXE driver
Published 2026-10-22 · **A1** Completely reliable, confirmed by other sources
Primary vendor advisory with technical root cause and credits.

[S4] CVE Program (TianoCore CNA): CVE-2026-97631 record
Published 2026-10-22 · **A1** Completely reliable, confirmed by other sources
CVSS v4 vector, CWEs 120/131/787, affected range through edk2-stable202608. Last updated 2026-10-28.

[S5] TianoCore edk2 (GitHub): PR #13302: NetworkPkg/UefiPxeBcDxe: Fix ICMP buffer overflow in IPv4/IPv6 handle (CVE-2026-97631)
Published 2026-10-15 · **A1** Completely reliable, confirmed by other sources
Upstream fix and commit hashes. Thread mentions broken embargo and an unverified claim that a flooder can still disrupt PXE.

[S6] oss-security mailing list: CVE-2026-97631: Pre-boot RCE in EDK II PXE driver
Published 2026-10-28 · **A1** Completely reliable, confirmed by other sources
Repost of the advisory plus Debian OVMF status.

[S7] Red Hat: CVE-2026-97631 - Red Hat Customer Portal
Published 2026-10-28 · **A2** Completely reliable, probably true
Preliminary CVSS 3.1 8.8 (AV:A). Product status not shown on the page fetched.

[S8] Debian Security Tracker: CVE-2026-97631
Published 2026-10-28 · **A1** Completely reliable, confirmed by other sources
edk2 vulnerable in bookworm, trixie, forky and sid. Lists upstream fix commits.

[S9] Microsoft Project Mu (GitHub): mu_basecore PR #1989: Backport CVE-2026-97631 from edk2
Published 2026-10-22 · **A1** Completely reliable, confirmed by other sources
Backport to release/202608.

[S10] Hardware Busters: EDK II Vulnerability Lets a Rogue ICMP Packet Run Code Before Secure Boot on PXE-Booting Systems
Published 2026-10-28 · **C3** Fairly reliable, possibly true
Secondary coverage. Its claim that AMI, Insyde and Phoenix firmware carry the component is not corroborated by vendor statements.

[S11] Cyber Security News: Critical UEFI Firmware Flaw Could Expose Millions of Servers to Pre-Boot Code Execution
Published 2026-10-28 · **C2** Fairly reliable, probably true
Secondary coverage with mitigation guidance and fix details.

[S12] Rescana: EDK II UEFI PXE Flaw CVE-2026-97631: Critical Pre-Boot Code Execution Risk, Patch Not Yet Released
Published 2026-10-28 · **C2** Fairly reliable, probably true
Vendor/distro status table as of 2026-10-28 (Fedora fixed builds in testing).

[S13] FIRST EPSS: EPSS API - CVE-2026-97631
Published 2026-10-28 · **A2** Completely reliable, probably true
EPSS 0.00483, percentile 0.41529.

[S14] CISA: Known Exploited Vulnerabilities Catalog (JSON feed)
Published 2026-10-28 · **A2** Completely reliable, probably true
Catalog version 2026.10.28. CVE not found in the portions reviewed. S2 and S12 confirm it was absent as of 2026.10.27.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2010-11-01	Vulnerable ICMP error copy loop introduced in edk2 (commit a3bcde70; exact day in November 2010 not stated).	[S2]

Date	Event	Source
2024-01-16	PixieFail (nine flaws in the same EDK II network stack) disclosed; follow-on fuzzing did not find this bug.	[S2] [S11]
2026-08-21	edk2-stable202608 released (affected).	[S2]
2026-09-14	Affected EDK II master snapshot referenced in advisory.	[S3]
2026-09-24	CVE-2026-97631 reserved.	[S4]
2026-09-28	Public PR #13200 (AMI engineer sign-off) describes the flaw and fix, breaking the embargo planned for January 2027.	[S2] [S12]
2026-10-15	Fix PR #13302 merged to edk2 master (commit fa789071).	[S5]
2026-10-22	TianoCore publishes GHSA-99cj-7hg9-mp4m and the CVE record. Project Mu backport merged.	[S3] [S4] [S9]
2026-10-26	Project Mu tagged builds and Fedora fixed builds (in testing) appear.	[S2] [S12]
2026-10-27	Ars Technica coverage. TianoCore maintainer states the embargo was broken by mistake.	[S6] [S12]
2026-10-28	oss-security post, The Hacker News article. CVE record updated. Not in KEV.	[S2] [S4] [S6]

Relevance to Indianapolis, Indiana & managed clients

Indiana organizations most exposed are those that image or reprovision machines over the network. That includes hospital and health-system data centers, the state and county government IT environments, universities and K-12 districts that reimage labs and student devices with WDS or MECM/SCCM PXE each term, and manufacturers that use PXE for plant-floor PCs and thin clients. Colocation and hosting providers in the Indianapolis area that offer bare-metal provisioning should also check their exposure. Small and mid-size businesses that boot only from local disk are largely unaffected, but should check for PXE left enabled or in the fallback boot order. For managed IT service clients, the practical steps are an inventory of which client sites run PXE imaging servers and which endpoints have network boot enabled, BMC/BIOS policy changes to disable PXE where it is not needed, confirmation that imaging VLANs are separated from user and guest Wi-Fi, and tracking of OEM firmware releases (Dell, HPE, Lenovo) for client server fleets. Because the attacker needs local or adjacent network access, flat networks typical of smaller clients raise the risk: one compromised workstation could disrupt or attack every machine that network-boots on the same segment.

Intelligence gaps

- Which OEM firmware lines (Dell, HPE, Lenovo, Supermicro, AMI, Insyde, Phoenix Aptio and others) are affected, and when they will ship fixes. No OEM advisory had been identified as of 2026-10-28.
- Status of hypervisor virtual firmware beyond Linux OVMF (VMware ESXi EFI, Hyper-V Gen2 UEFI, cloud provider firmware such as AWS and Azure). Amazon and Microsoft did not respond to press.
- Which ICMP/ICMPv6 message types the driver accepts, and whether intermediate routers forward oversized error messages. This affects how far from the target an attacker can realistically be, given 'any network distance' (advisory) versus 'adjacent network' (Red Hat/SUSE).
- Whether a public proof-of-concept exists and its capability. A PR commenter linked one and claimed flooding still disrupts PXE after the fix; this is unverified and was not examined.
- When a stable EDK II release (likely edk2-stable202611) will include the fix.
- No indicators of compromise or exploitation telemetry exist. Watch Eclypsium, Binarly and CERT/CC for follow-up research or a VU note.

Other notes

- Severity scoring differs by source. TianoCore's CVSS v4 9.5 uses AV:N with an attack requirement (AT:P). Red Hat and SUSE use CVSS 3.1 8.8 with AV:A, reflecting their view that adjacent-network access is needed.
- Disclosure was disrupted. A public PR on 2026-09-28 (signed off by an AMI engineer) exposed the flaw months before the planned January 2027 coordinated disclosure, and a TianoCore maintainer called it a mistake.
- Intel said its reference code does not include the affected functionality, although OEM boards may add it. Arm said the issue is not directly applicable to its portfolio. AMD, Phoenix, AMI, Microsoft, Amazon and TianoCore did not comment to The Hacker News.
- Researchers credited: Alex Matrosov (Anthropic) and Dan Holmes-Mitra (Google), who also supplied the recommended fix.
- Eclypsium's Jesse Michael noted that the fix is a plain code change that does not require Secure Boot key or certificate revocation (dbx) updates.
- Related prior EDK II/UEFI issues: PixieFail (2024, same network stack), LogoFAIL and PKfail.

CTI-20261029-04 v1.0 · Generated 2026-10-29 09:06 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.